

ESERCIZIO1: WINDOWS POWERSHELL

OBIETTIVI

- Parte 1 Accedere alla console PowerShell.
- Parte 2 Esplorare i comandi del Prompt dei Comandi e di PowerShell.
- Parte 3 Esplorare i cmdlet.
- Parte 4 Esplorare il comando netstat usando PowerShell.
- Parte 5 Svuotare il cestino usando PowerShell.

RISPOSTA ALLE DOMANDE

Quali sono gli output del comando dir?

In entrambe le shell l'output sono le directory presenti nella cartella corrente.

```
C:\Users\user>dir
Il volume nell'unità C non ha etichetta.
Numero di serie del volume: B008-65A2

Directory di C:\Users\user

11/04/2025  00:07  <DIR>      .
11/04/2025  00:07  <DIR>      ..
09/07/2024 16:37  <DIR>      Contacts
11/04/2025  00:00  <DIR>      Desktop
09/07/2024 18:05  <DIR>      Documents
09/07/2024 16:37  <DIR>      Downloads
09/07/2024 16:37  <DIR>      Favorites
09/07/2024 16:37  <DIR>      Links
09/07/2024 16:37  <DIR>      Music
09/07/2024 16:39  <DIR>      Pictures
09/07/2024 16:37  <DIR>      Saved Games
09/07/2024 16:39  <DIR>      Searches
09/07/2024 16:37  <DIR>      Videos
0 File             0 byte
13 Directory      20.141.649.920 byte disponibili
```

```
PS C:\Users\user> dir

Directory: C:\Users\user

Mode                LastWriteTime         Length Name
----                -
d-r---             09/07/2024         16:37      Contacts
d-r---             24/04/2025          00:00      Desktop
d-r---             09/07/2024         18:05      Documents
d-r---             09/07/2024         16:37      Downloads
d-r---             09/07/2024         16:37      Favorites
d-r---             09/07/2024         16:37      Links
d-r---             09/07/2024         16:37      Music
d-r---             09/07/2024         16:37      Pictures
d-r---             09/07/2024         16:39      Saved Games
d-r---             09/07/2024         16:37      Searches
d-r---             09/07/2024         16:37      Videos
```

Quali sono i risultati?

I 3 comandi restituiscono gli stessi risultati per entrambe:

- cd: permette di cambiare la cartella occupata.
- Ping: testa se ci sono connessioni attive con un certo IP.
- ipconfig restituisce informazioni sulla configurazione di rete.

Qual è il comando PowerShell per dir?

Il comando è Get-Children.

Qual'è il gateway IPv4?

Il gateway non è configurato.

Pv4 Tabella route

Indirizzo rete	Mask	Gateway	Interfaccia	Metrica
127.0.0.0	255.0.0.0	On-link	127.0.0.1	306
127.0.0.1	255.255.255.255	On-link	127.0.0.1	306
127.255.255.255	255.255.255.255	On-link	127.0.0.1	306
169.254.0.0	255.255.0.0	On-link	169.254.252.19	266
169.254.252.19	255.255.255.255	On-link	169.254.252.19	266
169.254.255.255	255.255.255.255	On-link	169.254.252.19	266
224.0.0.0	240.0.0.0	On-link	127.0.0.1	306
224.0.0.0	240.0.0.0	On-link	169.254.252.19	266
255.255.255.255	255.255.255.255	On-link	127.0.0.1	306
255.255.255.255	255.255.255.255	On-link	169.254.252.19	266

Quali informazioni puoi ottenere dalla scheda Dettagli e dalla finestra di dialogo Proprietà per il PID selezionato?

Le informazioni dalla scheda Dettagli ottenute riguardano: il nome del processo, il nome dell'utente che ha avviato il processo, la memoria RAM occupata, lo stato del processo e la CPU.

Nella scheda Proprietà si possono visualizzare le informazioni riguardanti: i permessi di sicurezza, data di creazione, percorso su disco, dimensioni, versione del file, data ultima modifica, nome del prodotto, tipo di file, il nome del file originale e il tipo di firma.

Cosa è successo ai file nel Cestino?

Il file è stato cancellato.

DOMANDA DI RIFLESSIONE

PowerShell è stato sviluppato per l'automazione delle attività e la gestione della configurazione. Usando internet, ricerca comandi che potresti usare per semplificare i tuoi compiti come analista di sicurezza. Registra le tue scoperte

Un analista di sicurezza può utilizzare PowerShell per automatizzare il monitoraggio, l'analisi delle minacce e l'audit dei sistemi. Di seguito sono riportati i comandi principali divisi per area operativa:

- **Analisi dei Processi e Servizi in Esecuzione**
 - Get-Process: Elenca tutti i processi attivi sul sistema. Consente di individuare processi sospetti, non riconosciuti o con un consumo anomalo di risorse.
 - Get-Service: Mostra lo stato di tutti i servizi di Windows per verificare che solo i servizi autorizzati siano in esecuzione.
- **Audit di Rete e Connessioni Attive**
 - Get-NetTCPConnection: Sostituisce il classico `netstat`. Permette di visualizzare le connessioni di rete attive, le porte aperte e i relativi processi (PID) collegati, utilissimo per rilevare comunicazioni verso IP dannosi.
 - Get-NetIPConfiguration: Fornisce i dettagli della configurazione di rete della macchina (IP, Gateway, DNS).
- **Analisi dei Log di Sicurezza (Event Viewer)**

- **Get-WinEvent -LogName Security:** Estrae i registri di sicurezza del sistema. Permette di automatizzare la ricerca di eventi critici, come tentativi di accesso falliti (Event ID 4625) o accessi riusciti (Event ID 4624).
- **Gestione degli Utenti e dei Permessi**
 - **Get-LocalUser:** Mostra gli account utente locali presenti sul sistema per identificare eventuali account non autorizzati o creati da malware.
 - **Get-LocalGroupMember -Group "Administrators":** Elenca i membri del gruppo degli amministratori locali per verificare l'assenza di escalation dei privilegi impropria.
- **Ispezione di File e Integrità**
 - **Get-FileHash:** Calcola l'hash (es. SHA256) di un file per verificarne l'integrità o per confrontarlo con i database di minacce (come VirusTotal).

ESERCIZIO BONUS: ESPLORAZIONE NMAP

OBIETTIVI

- Parte 1 Esplorazione di Nmap
- Parte 2 Scansione delle Porte Aperte

RISPOSTE ALLE DOMANDE

Cos'è Nmap? Per cosa viene usato nmap?

Nmap è un software open-source per analisi della rete e auditing di sicurezza. Permette di fare scansioni sia ai singoli dispositivi sia all'intera rete per ottenere varie informazioni come ad esempio:

- Se l'host risulta attivo.
- Servizi e versioni.
- Porte aperte.
- Sistema operativo del sistema.

Qual è il comando nmap usato? Cosa fa l'opzione -A? Cosa fa l'opzione -T4?

Il comando mostrato è `nmap -A -T4`, che permette scansioni molto aggressive della rete.
COMANDO -A: Abilita la scansione aggressiva permettendo di.

- Rilevare il sistema operativo (-O).
- Trovare le versioni dei servizi (-sV).
- Esegue script predefiniti per individuare vulnerabilità (--script=default).
- Traccia il percorso dei pacchetti.(--traceroute).

COMANDO -T4: È una scansione di tipo aggressiva, presupponendo una rete veloce e affidabile. Vieta un ritardo di scansione dinamico di oltre i 10 ms per le porte TCP.

Quali porte e servizi sono aperti?

Sono aperti:

- PORTA 21 (ftp) vsFTPD 3.0.5.
- PORTA 22 (ssh) 22/tcp open ssh OpenSSH 10.0 (protocol 2.0).

```
PORT STATE SERVICE VERSION
21/tcp open  ftp      vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-TW-I--I-- 1 0      0      0 Mar 26 2018 ftp_test
| ftp-syst:
|_STAT:
|_FTP server status:
|_  Connected to 127.0.0.1
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_  At session startup, client count was 3
|_  vsFTPD 3.0.5 - secure, fast, stable
|_End of status
22/tcp open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome
```

A quale rete appartiene la tua VM?

Appartiene alla rete 10.0.2.0/24, subnet mask 255.255.255.0.

```
4: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP gr
oup default qlen 1000
    link/ether 08:00:27:2f:87:a7 brd ff:ff:ff:ff:ff:ff
    altname enx0800272f87a7
    inet 10.0.2.15/24 metric 1024 brd 10.0.2.255 scope global dynamic enp0s3
        valid_lft 82842sec preferred_lft 82842sec
    inet6 fd17:625c:f037:2:a00:27ff:fe2f:87a7/64 scope global dynamic mngtmpaddr
noprfixroute
        valid_lft 86273sec preferred_lft 14273sec
```

Quanti host sono attivi?

C'è un solo host attivo nella rete, ossia la macchina su cui si sta facendo il laboratorio.

Qual è lo scopo di questo del sito scanme.nmap.org?

Il sito nasce per imparare l'utilizzo di Nmap e testare il programma, scansionando la pagina.

Quali porte e servizi sono aperti? Quali porte e servizi sono filtrati? Qual è l'indirizzo IP del server? Qual è il sistema operativo?

Secondo la scansione fatta sono state ricavate queste informazioni:

- IP → 45.33.32.156.

- **PORTE APERTE:** 22/tcp (ssh) open tcpwrapped.
80/tcp (http) open tcpwrapped Apache/2.4.7 (Ubuntu)
31337/tcp open tcpwrapped.
9929/tcp open tcpwrapped.
- **SISTEMA OPERATIVO:** Ubuntu.
- **PORTE E SERVIZI FILTRATI:** 996 porte filtrate.

L'analisi approfondita dei servizi non avviene, poiché la connessione si chiude bruscamente non permettendo analisi approfondita grazie a TCP Wrapper che fa da filtro.

```
[analyst@secops ~]$ nmap -A -T4 scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-09-04 11:20 -0400
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.21s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01:f03c:91ff:fe18:bb2f
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  tcpwrapped
|_ssh-hostkey: ERROR: Script execution failed (use -d to debug)
80/tcp    open  tcpwrapped
|_http-title: Go ahead and ScanMe!
|_http-server-header: Apache/2.4.7 (Ubuntu)
9929/tcp  open  tcpwrapped
31337/tcp open  tcpwrapped
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 72.89 seconds
```

DOMANDA DI RIFLESSIONE

Nmap è uno strumento potente per l'esplorazione e la gestione della rete. Come può Nmap aiutare con la sicurezza della rete? Come può Nmap essere usato da un attore malevolo come strumento nefasto?

Nmap aiuta gli amministratori a mantenere a rete sicura, poiché permette audit e analisi sullo stato della rete:

- Permette di identificare host sospetti all'interno della rete.
- Verificare se vi sono porte e servizi inutilmente in ascolto che possono costituire un punto di accesso per gli attaccanti.
- Permette anche di individuare alcune vulnerabilità per patcharle.

È uno strumento utile anche per gli attaccanti poiché:

- Individua target attivi nella rete.
- Scansiona porte e servizi che possono essere utili come vettori d'attacco.
- Analizza alcune vulnerabilità sfruttabili.

BONUS 2: ATTACCO AD UN DATABASE MySQL

OBIETTIVI

In questo laboratorio, visualizzerai un file PCAP di un attacco precedente contro un database SQL.

- Parte 1 Aprire Wireshark e caricare il file PCAP.
- Parte 2 Visualizzare l'attacco di SQL Injection.
- Parte 3 L'attacco di SQL Injection continua...
- Parte 4 L'attacco di SQL Injection fornisce informazioni di sistema.
- Parte 5 L'attacco di SQL Injection e le informazioni sulle tabelle.
- Parte 6 L'attacco di SQL Injection si conclude.

RISPOSTE ALLE DOMANDE

Quali sono i due indirizzi IP coinvolti in questo attacco di SQL injection in base alle informazioni visualizzate?

Gli IP coinvolti sono 10.0.2.4(attaccante) e 10.0.2.15(vittima).

28	441.804070	10.0.2.4	10.0.2.15	HTTP
----	------------	----------	-----------	------

Qual'è la versione?

La versione del sistema operativo 5.7.12-ubuntu1.1.

Quale utente ha l'hash della password di 8d3533d75ae2c3966d7e0d4fcc69216b?

L'utente è 1337.

```
first name: 1337<br />Surname: 8d3533d75ae2c3966d7
```

Qual'è la password in chiaro?

La password è charley.

hashes: 1 cracked: 1 partial: 0 not found: 0 invalid: 0		
Hash	Type	Result
8d3533d75ae2c3966d7e0d4fcc69216b	md5	charley

DOMANDE DI RIFLESSIONE

1. Qual è il rischio che le piattaforme utilizzino il linguaggio SQL?

2. Naviga in internet ed esegui una ricerca per “prevenire attacchi di SQL injection”. Quali sono 2 metodi o passaggi che possono essere adottati per prevenire gli attacchi di SQL injection?

Il linguaggio SQL è rischioso per le piattaforme, poiché possono essere vittima di attacchi SQL injection, che possono portare ad un'esfiltrazione di dati come le credenziali o la modifica e cancellazione del database, ma ci sono accortezze che riducono la possibilità di un attacco:

- **Convalida e sanificazione dell'input:** Consiste nel verificare che i dati inseriti dall'utente rispettino il formato atteso (tramite *whitelist* di caratteri consentiti) e nel rimuovere o neutralizzare i caratteri speciali pericolosi come gli apici singoli ('), i punti e virgola (;) o i trattini doppi (- -).
- **Utilizzo di query parametrizzate:** Separa nettamente il codice SQL dai dati inseriti dall'utente, facendo in modo che il database tratti l'input esclusivamente come valore letterale e non come istruzione eseguibile.
- **Stored Procedure:** Incapsulano la logica delle query direttamente all'interno del database, limitando la possibilità di alterare la struttura del comando tramite parametri esterni.
- **Web Application Firewall (WAF):** Un filtro a livello di rete e applicativo in grado di intercettare, analizzare e bloccare pattern di attacco noti prima che raggiungano l'applicazione web.

